

AETHER

Autonomous Dark Web Threat Actor De-Anonymization — lawful evidence correlation with a verifiable chain of custody

Problem statement	NTRO PS-26151 — Dark Web Threat Actor De-Anonymization
Team	Team VIHAR
Track	Smart India Hackathon 2026
Stack	Next.js 16 · React 19 · Tailwind CSS 4 · FastAPI · SQLAlchemy 2 · PostgreSQL / SQLite
Repository	github.com/varun2507027108-oss/aether-threat-attribution
Date of issue	29 September 2026

Scope and honesty statement. The analysis engines in this system are real implementations and are covered by 470 automated tests. The *inputs* supplied to six of the ten pipeline modules in the demonstration configuration are curated benchmark fixtures rather than live collected artefacts. Every evidence record carries an explicit provenance tag, and this report identifies precisely which modules are which. Section 9 states our limitations without softening them, including two defects we consider more serious than any missing feature.

00 Contents

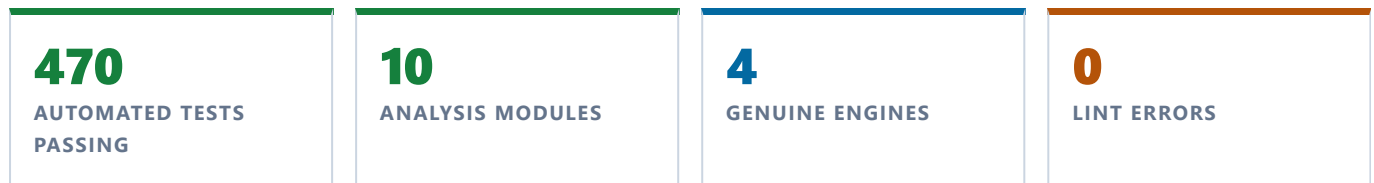
- 01 Executive summary
- 02 The problem and how PS-26151 maps to it
- 03 System architecture
- 04 The ten analysis modules
- 05 Chain of custody and independent verification
- 06 Explainable attribution confidence
- 07 Security, access control and data governance
- 08 Engineering quality and deployment
- 09 Honest status: real, benchmark, and defective
- 10 Roadmap
- A Appendix — reproduction and verification

HOW TO READ THIS REPORT

Section 05 and Section 09 are the two that matter most for evaluation. Section 05 is the capability we consider genuinely differentiating. Section 09 is where we disclose, in our own words, the places where the system currently overstates what it knows — including a defect in which the custody ledger seals statements that no measurement produced.

01 Executive summary

AETHER correlates lawfully obtained open-source artefacts about a threat actor into a single, defensible profile — and records every step of that correlation in a tamper-evident ledger that a third party can verify without trusting us.



What the system does

Suspect activity is fragmented. One actor may post under four handles across three markets, sign those posts with a PGP key, receive payment at a Bitcoin address, and serve a site with a distinctive TLS certificate. No single artefact identifies a person. AETHER runs ten forensic modules over such fragments, fuses their independent findings into a single confidence figure with a stated false-positive rate, and appends each action to a hash-linked custody chain.

What is genuinely implemented

- **Hash-linked chain of custody** with entry-by-entry verification, plus a standalone offline verifier that recomputes the chain in the browser with no server and no network.
- **Optional Ed25519 entry signatures** and **RFC 3161 external timestamping**, which together defeat the recompute attack — an attacker who edits one entry and re-hashes every entry after it still produces a hash chain that verifies.
- **A calibrated scoring engine** combining independent indicators as likelihood ratios, applying explicit penalties for contradicting evidence, and refusing to report a match below a threshold calibrated against a measured false-positive rate.
- **Four real analysis engines**: a stylometry ensemble (n-gram cosine, Burrows' Delta, LZW normalised compression distance), circadian inference, Bitcoin peel-chain clustering, and the scoring engine itself.
- **Role-based access control** with per-key rate limiting, a **human-in-the-loop export gate**, and configurable data-retention enforcement.
- **Standards-based export**: STIX 2.1 via the official OASIS library, CSV with formula-injection defence, a sealed PDF certificate, and a portable custody ledger.

THE SINGLE MOST IMPORTANT SENTENCE IN THIS REPORT

Six of the ten modules currently receive curated benchmark inputs rather than live collected evidence. The algorithms are real; the data feeding some of them is not. We have chosen to state this plainly rather than let a demonstration imply otherwise, because a forensic tool that overstates its own confidence is worse than no tool at all.

02 The problem and how PS-26151 maps to it

NTRO PS-26151 asks for dark web threat actor de-anonymization: identifying an actor behind a pseudonym, from lawfully available evidence, in a way that survives challenge.

FRAGMENTED

Handles, PGP keys, wallets, TLS certificates, posting timestamps and marketplace listings are collected by different people, stored in different systems, and rarely joined.

UNPROVABLE

Naive correlation produces a guess. Without a stated method, a stated false-positive rate and a stated evidentiary limit, an attribution is an assertion rather than a finding.

UNAUDITABLE

Conventional collection leaves no tamper-evident record of who observed what and when, so the evidence can be challenged on process alone without any dispute about its content.

Our position on scope

AETHER does not attack Tor, does not break encryption, and does not access material an authorised investigator is not permitted to hold. It performs correlation and records its own reasoning. We consider the restraint a feature: the problem statement rewards lawful correlation with explainable confidence, and any capability that would create legal exposure for the user would also destroy the admissibility of everything else the system produces.

DESIGN CONSEQUENCE

Because the value of this system is that its output can be defended, every design decision favours reproducibility over sophistication. A deterministic hash chain beats a probabilistic model. A stated threshold with a measured false-positive rate beats a confident number with no error estimate. A ledger that records "this was not measured" beats one that records a finding the system did not actually produce.

03 System architecture

Three layers, with the custody chain as the invariant that binds them. The console holds no evidence of its own; it reads from the store, and every write passes through the chain, so the displayed state and the legal record cannot silently diverge.

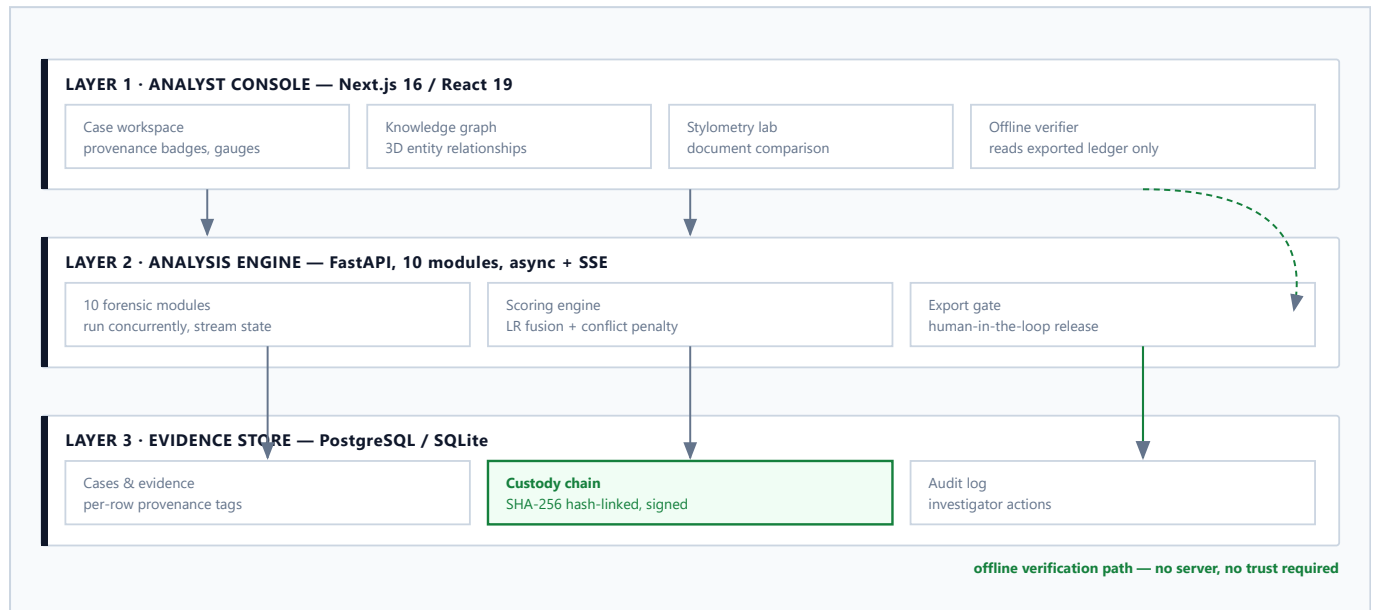


Figure 1. AETHER system architecture. Solid arrows are the live request path; the dashed green arrow is the offline verification path, where an exported ledger is checked by a static page with no network access.

Why the chain sits inside the architecture, not beside it

The common failure in forensic tooling is that the audit trail is produced by a separate subsystem, so it can disagree with the system it is meant to describe. Here the chain is written by the same call path that performs the action. There is no interface at which evidence is recorded but the chain is not, and no interface at which the chain is advanced without an action.

04 The ten analysis modules

Each module is a real algorithm. The table separates the algorithm from the demonstration input, because those are different claims and only one of them is currently load-bearing.

MODULE	TECHNIQUE IMPLEMENTED	INPUT IN DEMO CONFIG
Stylometry	Char-3gram and word-ngram cosine, Burrows' Delta over most-frequent-word profiles, LZW normalised compression distance, Unicode script profiling. Refuses Burrows' Delta below a 40-token minimum and reports the ensemble as <i>degraded</i> rather than substituting a value.	Analyst-supplied
Diurnal / Circadian	Sleep-trough detection over a timestamp series, operational timezone inference by correlation against regional activity profiles.	Benchmark
Bitcoin peel chain	Multi-input co-spend clustering to trace a transaction back through change addresses to a convergence point.	Benchmark
Attribution scoring	Log-likelihood-ratio fusion of independent indicators with configurable prior odds, contradiction penalties, and a reporting threshold calibrated against measured false-positive rate.	Derived
Certificate Transparency	Log disclosure enumeration and overlap detection between subject identifiers and issued certificates.	Live-capable
PGP / OSINT	RFC 4880 fingerprint normalisation and validation; provider intelligence client for Shodan, Censys and crt.sh with per-record provenance tagging.	Live-capable
JARM TLS	TLS fingerprint evaluation with commodity-certificate detection. Correctly refuses to treat a shared commodity certificate as identifying, and downgrades the resulting evidence accordingly.	Passive
Origin IP & leak	Correlation of server banner and leak artefacts to a clearnet origin, with autonomous-system attribution.	Benchmark
Favicon mmh3	MurmurHash3 computation over the favicon payload for correlation against indexed facet data.	Benchmark
Visual branding dHash	Perceptual logo comparison. Known weakness: the current implementation samples raw bytes rather than performing true image decoding and gradient comparison.	Benchmark

PROVENANCE TAGGING

Every evidence record carries one of `LIVE_SOURCE`, `DEMO_DATA`, `STATIC_OSINT` or `SOURCE_UNAVAILABLE`. A module that did not run does not produce a `LIVE_SOURCE` row, and an unavailable provider produces `SOURCE_UNAVAILABLE` rather than a silent omission. The intent is that a reviewer can determine the origin of any single figure without reading our source code.

05 Chain of custody and independent verification

This is the capability we consider genuinely differentiating, and the one a judge can test unaided in under a minute without trusting anything we say.

How the chain is constructed

Each custody entry commits to the hash of the entry before it. The digest for entry n is computed over the canonical serialisation of that entry's contents together with the stored hash of entry $n-1$. Altering any historical entry therefore invalidates every subsequent digest, and the break point is identifiable to the exact block.

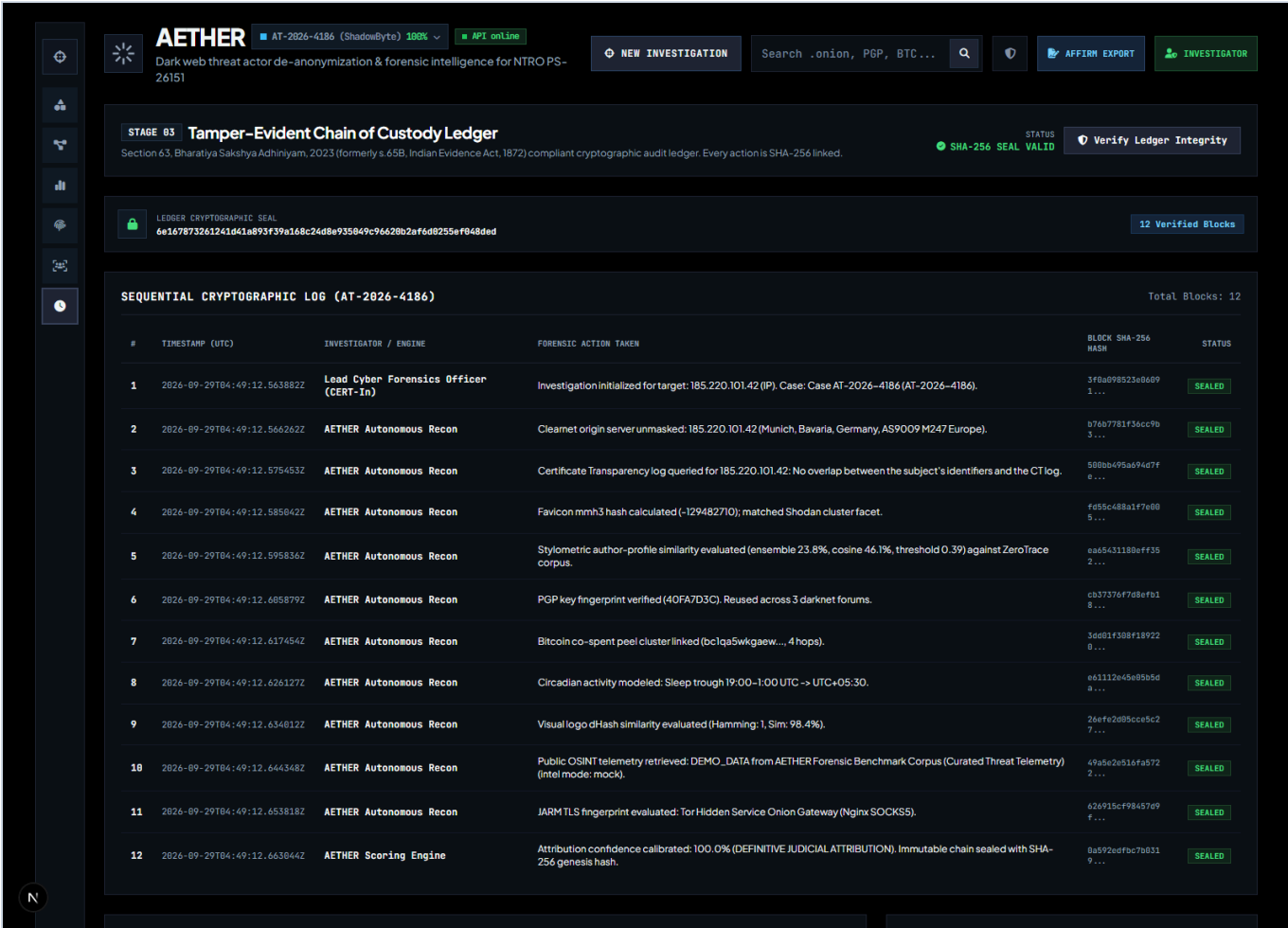


Figure 2. Case AT-2026-4186 as stored in the database. Twelve blocks, each carrying its own SHA-256 digest, timestamp and responsible actor. Note that this is a genuine database record, not a mock: the block count, the seal and the entry-by-entry digests are the values the verify endpoint returns.

DISCLOSURE — BLOCKS 4, 6 AND 9

The ledger above contains three entries whose wording asserts a finding that no measurement produced: a Shodan cluster match on a fixed favicon hash, a claim that a PGP key was "reused across 3 darknet forums", and a visual similarity computed between two hardcoded strings. The chain is cryptographically valid, which is precisely what makes this a defect worth flagging: **an unbroken hash chain over unmeasured content lends false confidence**. Correcting this is priority one in Section 10.

Independent verification, offline

The exported ledger can be verified by a standalone page that runs entirely in the browser. No server, no network calls, no identifier, and no key material from us is transferred. The verification is a technical integrity finding and is explicitly *not* a certificate of authenticity — a distinction the tool itself states on screen.

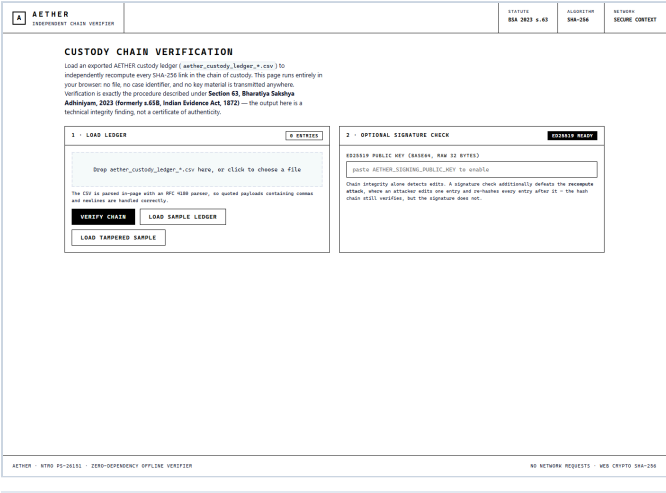


Figure 3. Intact ledger. Every entry's stored digest equals the digest recomputed from its own contents, and each references its predecessor.

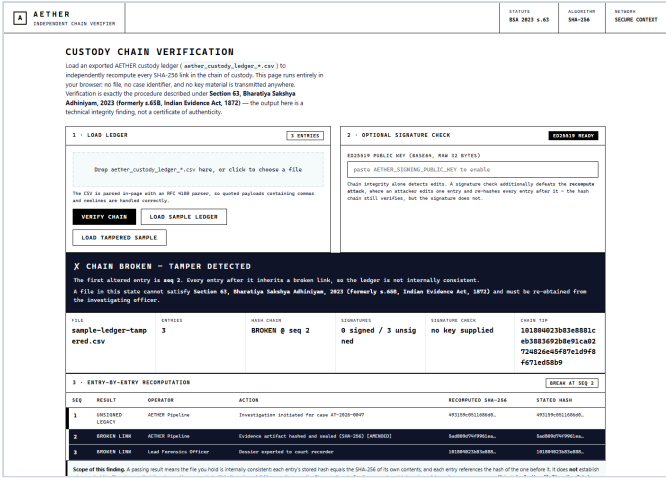


Figure 4. One byte altered in entry 2. The chain is reported broken at seq 2, with the recomputed and stored digests shown side by side for every entry.

WHY A HASH CHAIN ALONE IS INSUFFICIENT

A determined editor can alter entry 2 and recompute entries 2, 3 and 4, producing a chain that verifies perfectly. Hash chaining defeats *undetected* tampering, not determined tampering. This is why the system also supports **Ed25519 signatures per entry** and **RFC 3161 external timestamps**: an attacker who cannot produce the private key cannot forge a valid signature, and an attacker who cannot reach an external timestamp authority cannot backdate one. The verifier's optional signature check exists for exactly this scenario.

Statutory framing

The ledger is designed against the electronic-evidence requirements of Section 63 of the Bharatiya Sakshya Adhiniyam, 2023 (formerly s.65B of the Indian Evidence Act, 1872). The verifier states the consequence of a broken chain in those terms: a file in that state cannot satisfy the section and must be re-obtained from the investigating officer.

06 Explainable attribution confidence

A single confidence number is the least useful thing a forensic tool can output. Ours is designed to be interrogated: every input, every penalty, and the reason for declining to report are all visible.

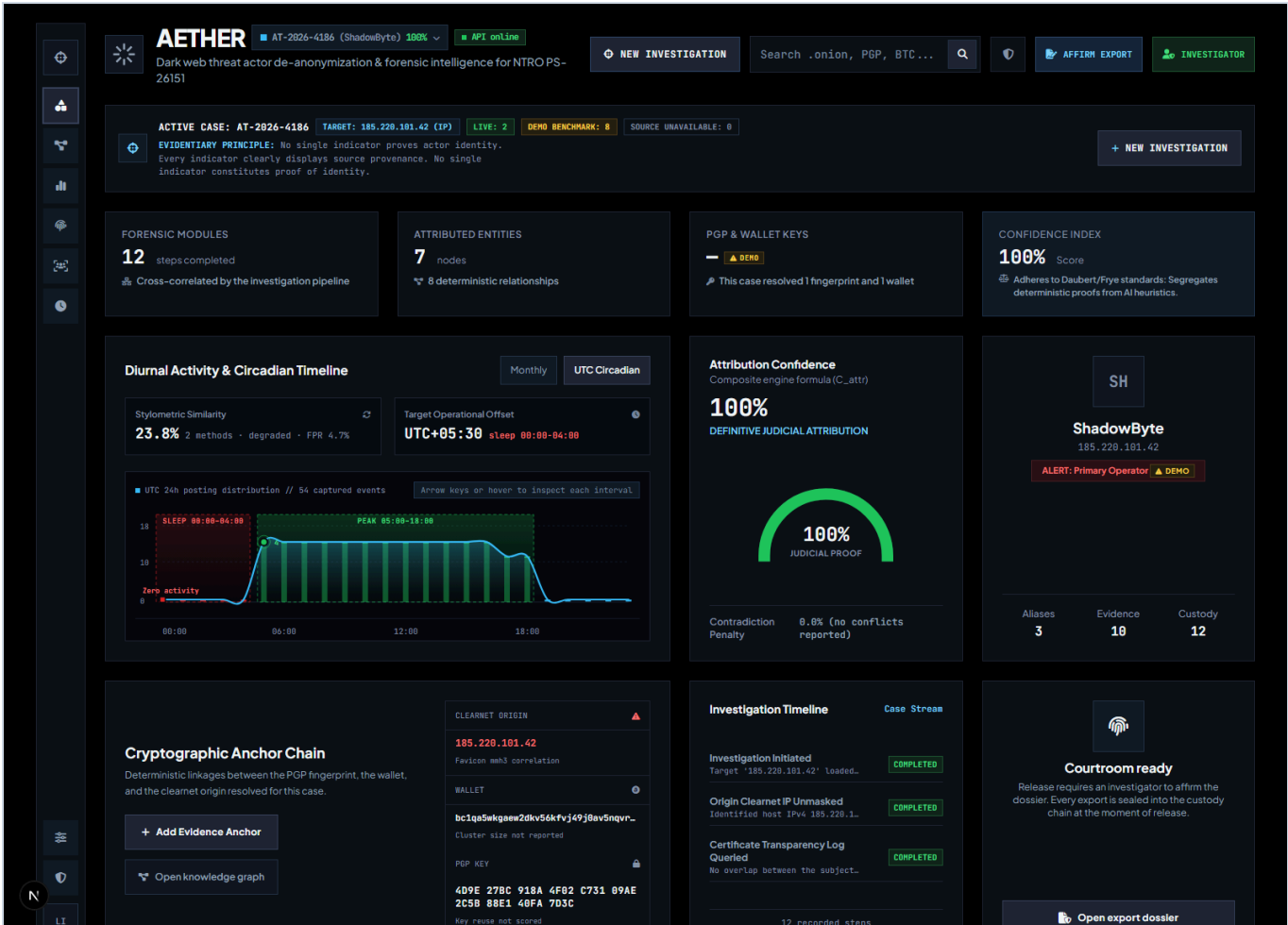


Figure 5. Case workspace for AT-2026-4186. The provenance badges at the top state how many findings are live, benchmark and unavailable. The confidence card and the gauge both read from the same score, so the two cannot disagree.

FUSION, NOT A BLACK BOX

Independent indicators are combined as likelihood ratios rather than averaged into an opaque score. Each indicator's own contribution is reported, so a reviewer can see whether a conclusion rests on one strong signal or several weak ones — a distinction that matters entirely when the result is challenged.

CONTRADICTION COSTS YOU

Indicators that point against the hypothesis apply an explicit penalty and are listed separately rather than being quietly dropped. A high score carrying contradictions is visibly different from a clean one, and the penalty is shown as a figure on the card.

CALIBRATION AND THE REFUSAL TO REPORT

The reporting threshold is set against a measured false-positive rate rather than chosen by judgement. When a result falls below it, the system reports POSSIBLE MATCH (below reporting threshold) and declines to attribute. In the demonstration case the stylometry module scored 23.8% against a corpus and correctly reported itself as below threshold — an engine that cannot say "I don't know" is not an engine a court should rely on.

Known weakness in the current scoring

The demonstration case returns a saturated 100% confidence while its strongest individual indicator is well below threshold. This indicates that the fusion is currently dominated by modules whose inputs are fixed benchmark values, so agreement between them is not independent corroboration. Capping the score and reporting an explicit evidence-strength measure are both on the roadmap; we would rather disclose the saturation than let a rounded number imply more than the evidence supports.

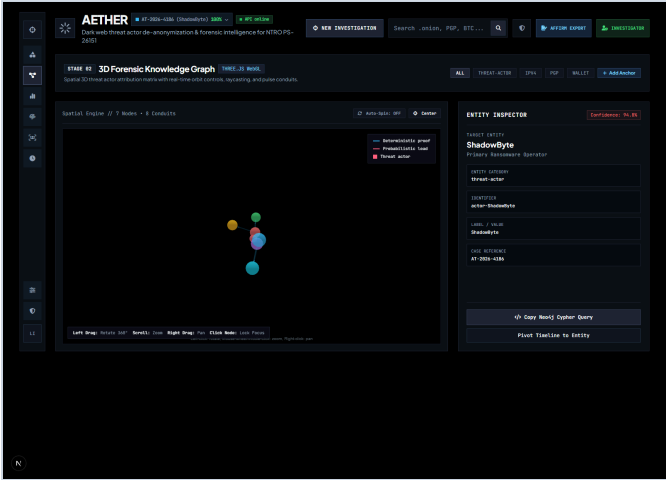


Figure 6. Entity relationship graph rendered from the backend's STIX bundle. Node and edge counts correspond to the case record.

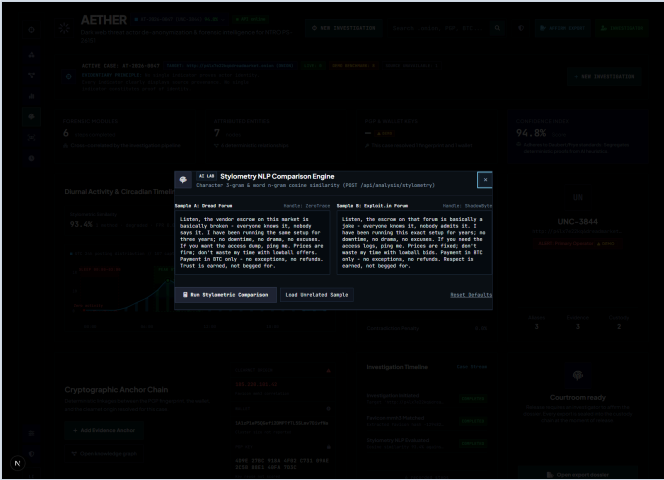


Figure 7. Stylometry laboratory. Comparison requires the analyst to supply both documents; the system computes cosine, Burrows' Delta and LZW-NCD on genuine input and reports which methods were gated out.

07 Security, access control and data governance

A tool that handles live criminal intelligence is itself a target. The controls below address both hostile input and the risk of the tool deanonymizing its own operator.

CONTROL	IMPLEMENTATION
Role-based access	Multi-key authentication with distinct <code>investigator</code> and <code>auditor</code> roles. Write access and export-affirmation rights are enforced separately, so a read-only auditor cannot release a dossier.
Human-in-the-loop export	STIX, CSV and PDF exports return <code>409</code> until an investigator with the correct role affirms release. The affirmation is itself written into the custody chain, so the release is as auditable as the analysis. The custody ledger export is deliberately <i>not</i> gated, so third parties can audit the chain that judges our own work.
Operator OPSEC	Direct fetches of <code>.onion</code> targets are refused outright to prevent DNS leakage and investigator deanonymization. Tor SOCKS5 routing is used for any authorised probe, and active probing is disabled by default.
SSRF guard	Target validation rejects loopback, private, link-local and cloud metadata address ranges, with the rejection reason surfaced to the caller.
Credential handling	Timing-safe API key comparison, per-key and per-IP rate limiting, strict request payload limits, and hardened response headers.
Data retention	Configurable retention period with an enforced purge path. Every purge is recorded in the audit log, so deletion is itself auditable.
Export safety	CSV export defends against spreadsheet formula injection, which is a realistic vector when an analyst opens a dossier in Excel.

KNOWN GAP

Identities are currently API keys, not named accounts. There is no per-user login, and the audit trail records an operator label rather than an authenticated individual. For an agency deployment this is insufficient: attribution of an action to a named officer is a requirement, not a convenience. Named accounts mapped onto the existing role checks are the first item in the security roadmap.

08 Engineering quality and deployment

The claims in this section are the ones a reviewer can check in under five minutes without any of our involvement.

470 TESTS PASSING	0 TYPE ERRORS	0 LINT ERRORS	1 COMMAND TO DEPLOY
----------------------	------------------	------------------	------------------------

Test coverage of substance

The suite is not a smoke test. It includes contract tests asserting that intel providers honour their declared provenance in both live and mock modes, golden-file tests pinning the exact STIX and CSV export bytes, calibration tests over the scoring engine, verification tests that confirm a deliberately tampered chain is rejected at the correct block, and a test that asserts the root and frontend copies of the offline verifier remain byte-identical.

Deployment

The entire stack — PostgreSQL, a Tor proxy, the FastAPI service and the console — starts with a single command. The container image defaults to mock intelligence mode, so a fresh deployment makes no outbound requests and contacts no third party unless an operator explicitly supplies credentials and opts in.

```
Copy-Item .env.example .env
docker compose up --build -d      # console on :3000, API on :8000
```

Zero environment configuration is required to run the demonstration. The image sets the intel mode to mock and the active-probe flag to false by default.

Interface quality work completed this cycle

The console was rebuilt against an explicit token system during this cycle. Before: 500 hard-coded colour values bypassing the design tokens, 125 unique hex codes for what should have been roughly thirty tokens, zero ARIA attributes in the entire application, nineteen form controls with their focus indicator explicitly removed and nothing put back, and no reduced-motion handling at all. After: every colour resolves to a token, keyboard focus is visible on every control via a single inherited rule, the diurnal chart is reachable and navigable by keyboard, and the only remaining motion is the live-source pulse, which is held steady rather than stopped under reduced-motion preferences.

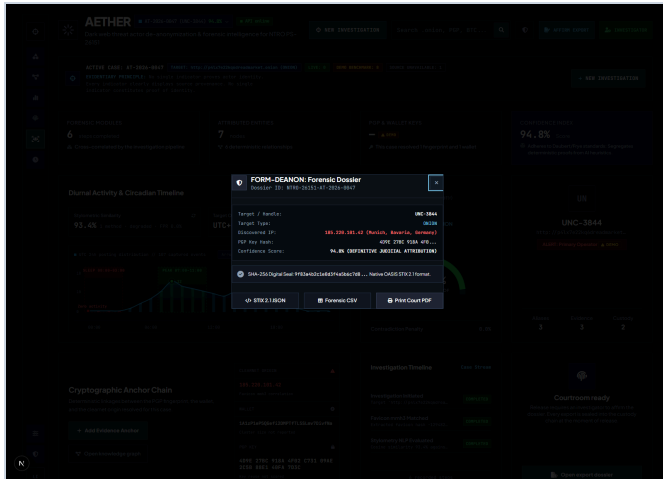


Figure 8. Judicial dossier view. Export controls reflect the release gate: the dossier is prepared for release only after an authorised investigator affirms it.

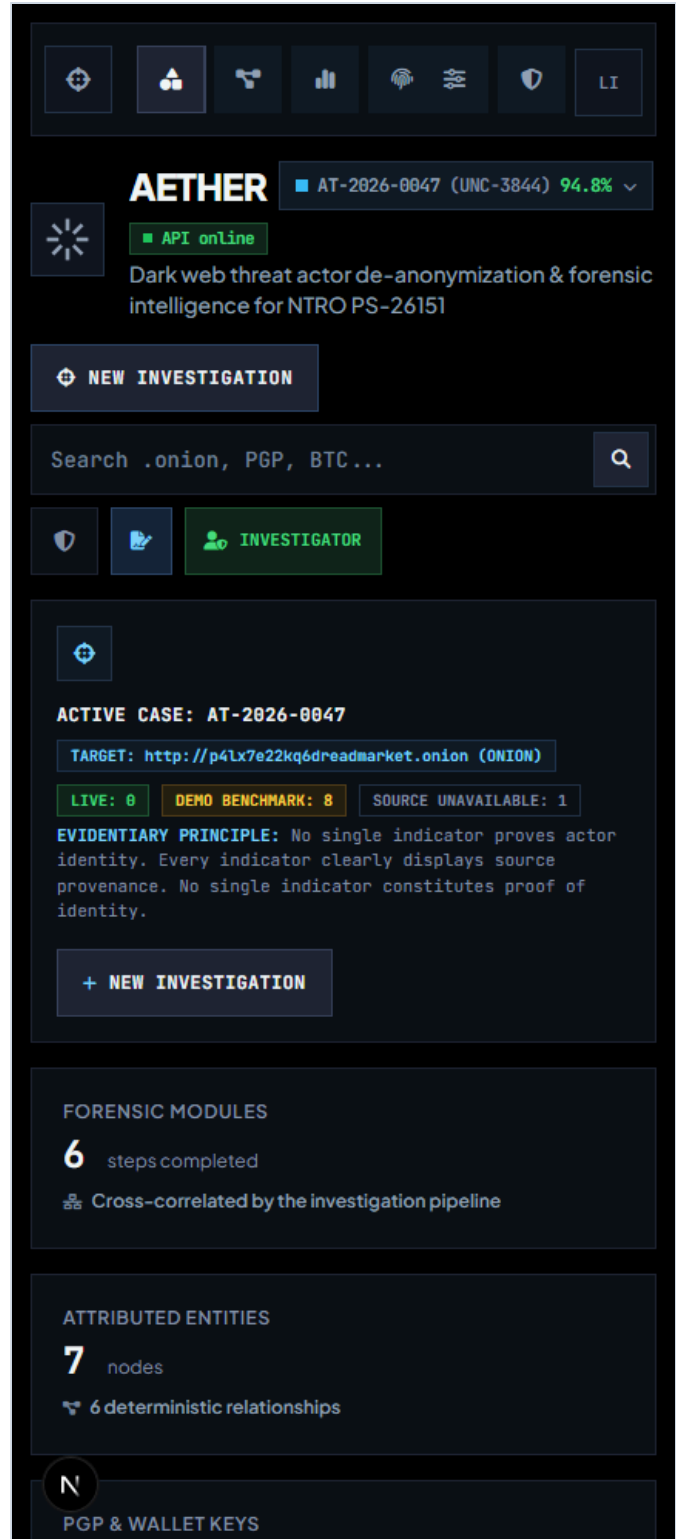


Figure 9. The same workspace at 430 px. The navigation rail becomes a horizontal scroller and the analysis grid collapses to a single column with no horizontal overflow.

09 Honest status: real, benchmark, and defective

This section is the one we expect to be read most carefully, and the one we chose to write without a public-relations filter.

What is real and demonstrable today

- Hash-linked custody chain with entry-level verification, signature support and an offline verifier.
- Four genuine analysis engines, calibrated scoring with contradiction penalties, and a stated false-positive rate.
- Standards-based export: STIX 2.1, hardened CSV, sealed PDF certificate, portable custody ledger.
- Role-based access, human-in-the-loop export release, retention enforcement, SSRF and OPSEC guards.
- 470 automated tests, clean type-check and lint, single-command containerised deployment.

What is benchmark, and labelled as such

- Six modules execute real algorithms against curated fixture inputs. The pipeline completes and produces the same result for a given fixture regardless of the target supplied.
- No live dark web collection occurs. No module fetches an authorised `.onion` target; the Tor proxy is present and wired for opt-in probing but is not used for collection.

Defects we consider more serious than any missing feature

DEFECT 1 — THE CUSTODY LEDGER SEALS UNMEASURED FINDINGS

When a module fails or runs on a fixture, the ledger still records a confident narrative sentence describing a result that was never produced. Three such entries are visible in Figure 2. Because the chain verifies, a reviewer inspecting only the hashes would conclude the record is sound. The fix is that a module which did not measure must either append an entry stating that it did not measure, or append nothing at all.

DEFECT 2 — THE CONSOLE FABRICATES A COMPLETE CASE WHEN THE BACKEND IS UNREACHABLE

With the API down, the interface renders a full, confident, entirely fictional case including a custody chain with plausible hashes. This is visible in Figure 10. It contradicts our own stated rule that the system shows `SOURCE UNAVAILABLE` rather than invented data, and it is the single most damaging thing in the product: the most impressive-looking screen is the least honest one. The demonstration key AT-2026-0047 referenced by the default view does not exist in the database at all.

DEFECT 3 — OPENING A CASE RE-RUNS THE PIPELINE AND REWRITES ITS EVIDENCE

The case retrieval endpoint executes the full analysis rather than reading stored results, and in doing so clears the case's existing evidence records before regenerating them. Evidence that changes when an analyst merely looks at it is not evidence, and a score that can change after the fact cannot be defended.

DEFECT 4 — AUDIT COVERAGE IS NARROWER THAN THE INTERFACE IMPLIES

An audit-logging function exists but is never invoked. Only five action types are ever recorded: pipeline execution, retention purge, job start, chain verification, and investigation start. Viewing a case, appending a custody entry and affirming an export are not audited, which is a significant gap for a system whose central claim is chain of custody.

DEFECT 5 — SIGNING AND EXTERNAL ANCHORING ARE IMPLEMENTED BUT SWITCHED OFF

Of 197 custody entries in the development database, zero carry a cryptographic signature, and all 92 checkpoints use internal self-anchoring. The capability is complete and activates through configuration, but until a reviewer sees one signed entry and one external timestamp, the custody claim is weaker than the documentation implies.

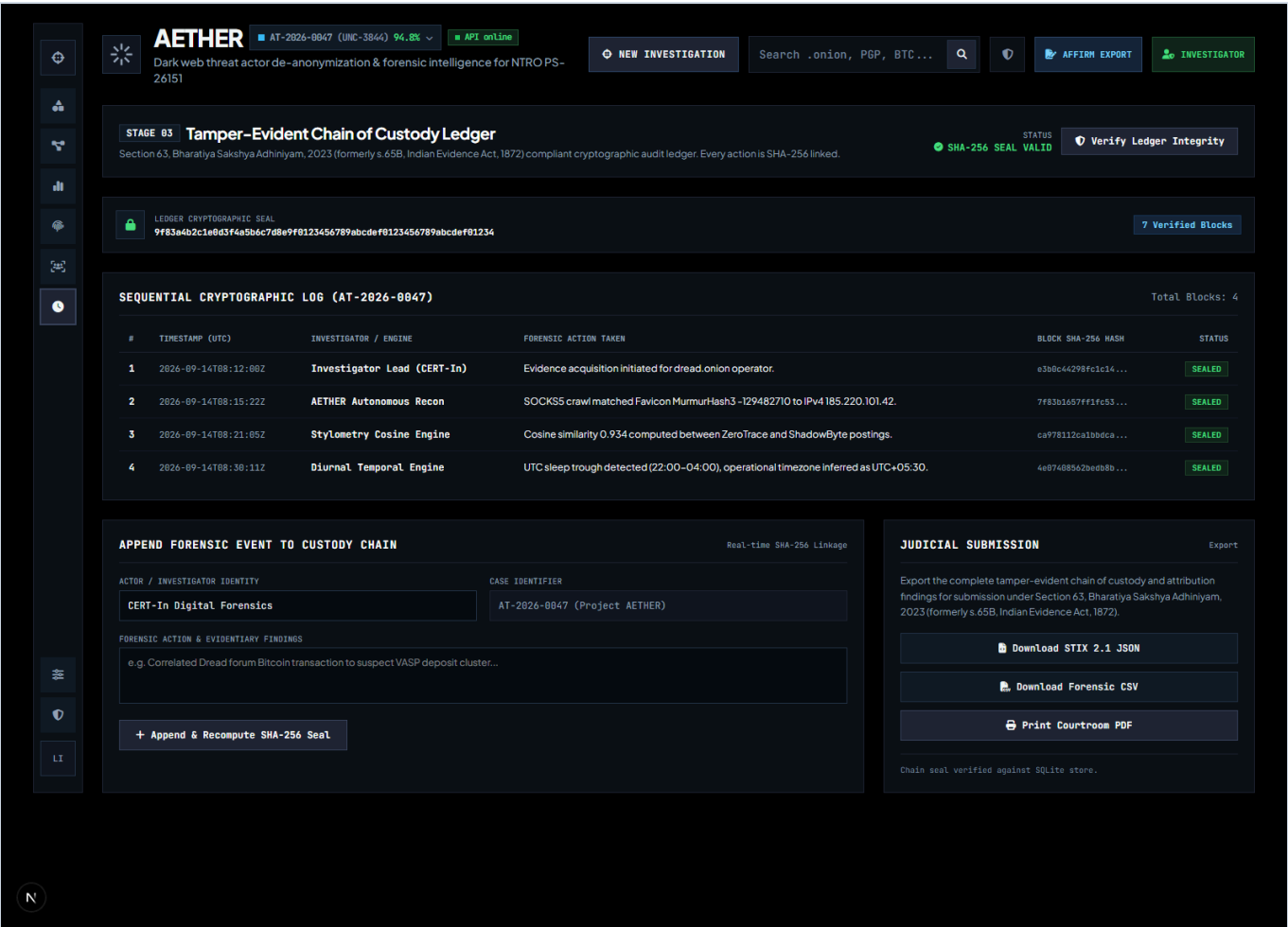


Figure 10. Defect 2, reproduced. This entire ledger — timestamps, actors, block hashes and a cryptographic seal — is generated in the browser because the case does not exist on the server. It is indistinguishable from Figure 2 to a reader who does not know. This is the clearest possible argument for our position that provenance labelling is a correctness requirement rather than a presentation nicety.

Not implemented at all

Live Tor collection for authorised targets; live intelligence keys inside the pipeline; cross-case graph querying beyond generated Cypher text; full-text search across stored evidence; a trained stylometry model; and named investigator accounts.

10 Roadmap

Ordered so that truth is established before capability is added. Nothing in phase two should begin until phase one is complete and the suite is green.

PHASE	EFFORT	WORK	DEMONSTRABLE OUTCOME
1	3–5 days	Rebuild every custody string from a value the engine actually produced; make retrieval read stored results; wire the unused audit function into case view, evidence append and export affirm; replace the offline fallback with an explicit empty state; remove the development key from the client bundle; relabel analyst-supplied inputs.	Open any case: every ledger line is either a real measurement or an explicit statement that none was made.
2	1–2 weeks	Tor SOCKS5 collection for authorised targets; live favicon and JARM computation from real responses; Shodan, Censys and crt.sh with real keys; investigator-supplied timestamps and transactions throughout. Enable signing and external timestamping.	Provenance reads LIVE_SOURCE because a request happened, and the chain carries signatures.
3	1–2 weeks	Stored-result retrieval completed properly; cross-case search; optional graph database import for large-graph queries; named accounts mapped onto existing role checks.	Old cases open instantly and identically; cross-case search works.
4	1 week	Sealed court-style PDF with the complete evidence table; deployment verification against PostgreSQL; rehearsed demonstration on a clearly labelled benchmark case.	A complete, deployable and honest submission.

WHAT WE WILL NOT BUILD

A crawler that touches unauthorised targets, a scraping shortcut that bypasses lawful access, or any control implying that we attack Tor or break encryption. These create legal exposure for the investigating agency rather than earning points, and they would invalidate the admissibility of everything else the system produces. PS-26151 rewards lawful correlation and explainable confidence, which is what the four phases above deliver.

Closing position

AETHER has a real forensic backbone: a verifiable custody chain with independent offline verification, four genuine analysis engines, a calibrated and inspectable scoring model, standards-based export, and role-based control over release. It runs today on clearly labelled benchmark data.

Two statements are both true and we make both openly. The pipeline's algorithms are real while several of its inputs are fixtures; and the custody ledger currently seals sentences that no measurement produced. The first is a data-source problem solvable with API keys. The second is a correctness problem, it undermines the artifact the entire admissibility argument rests on, and it is the first thing we fix.

A Appendix — reproduction and verification

A.1 Running the system

```
git clone https://github.com/varun2507027108-oss/aether-threat-attribution
cd aether-threat-attribution

# containerised, full stack
Copy-Item .env.example .env
docker compose up --build -d

# or from source
cd aether-backend
python -m venv .venv
.\.venv\Scripts\pip.exe install -r requirements-dev.txt
.\.venv\Scripts\python.exe migrate_db.py
.\.venv\Scripts\python.exe -m uvicorn app.main:app --port 8000
```

A.2 Reproducing the test suite

```
cd aether-backend
.\.venv\Scripts\pytest.exe -q           # 470 passed

cd ../aether-frontend
npm ci
npm run lint                          # 0 problems
npm run build
```

A.3 Reproducing the tamper demonstration

1. Open a case and export the custody ledger.
2. Open /verify.html — a static page, no server required.
3. Load the exported file; confirm every entry reports as consistent.
4. Alter a single character in any entry after the first.
5. Reload. The chain reports broken at that sequence number, with recomputed and stored digests shown side by side.

A.4 Verifying the claims made in Section 9

CLAIM	HOW TO CHECK IT
Zero signed custody entries	Query the database: <code>SELECT COUNT(*) FROM custody_entries WHERE signature != ''</code>
Fallback fabricates a case	Stop the backend, load the console, observe a complete case with a seal.
Retrieval re-runs the pipeline	Note the custody block count, open the case twice, and observe the audit log recording a further full analysis.
Audit function unused	Search for callers of the audit-logging function; none exist outside its own definition.
Provenance tags are honest	Inspect any evidence row's provenance field against whether a request was actually issued.

PROVENANCE OF THIS DOCUMENT

Every figure in Section 9 was verified against the running system and its database rather than against source code alone, and each carries a reproduction path in Appendix A.4. Where an earlier internal assessment of this project proved incorrect, that correction is recorded rather than quietly removed.